

CYBERSECURITY

PENETRATION TEST & CVE FINDINGS REPORT

Target Environment: Isolated Lab Network
Target Host: 192.168.211.129 (Metasploitable2)
Prepared by: Mark Waako (112107263)
Date: August 4, 2026

CONFIDENTIAL — For authorized internal training use only

1. Executive Summary

This report documents the results of an authorized penetration test performed against a single host (192.168.211.129) running the intentionally vulnerable Metasploitable2 distribution, within an isolated lab environment used for cybersecurity training. The objective was to identify exploitable weaknesses, gain unauthorized access, and assess the impact of a full compromise.

Testing identified three critical-risk findings: (1) weak and default credentials across multiple exposed network services, (2) insecure file permissions on the FTP service that exposed a private SSH key, and (3) an insecure sudo configuration that allowed trivial privilege escalation to root. Chained together, these findings allowed a tester with only network access to the host to obtain full root-level control of the system in a matter of minutes.

#	Finding	CVE / Reference	Risk
1	Weak / Default Credentials on Exposed Network Services (FTP, HTTP/Tomcat, PostgreSQL, SMB, rlogin, MySQL)	CWE-521 / CWE-1391 CVE-2010-4870 (rel. Tomcat)	Critical
2	World-Readable SSH Private Key Disclosed via FTP	CWE-276 / CWE-522	Critical
3	Insecure Sudo Configuration Allowing Privilege Escalation to Root	CWE-250 / CWE-269	Critical
4	Outdated / Vulnerable Service Version (vsftpd 2.3.4)	CVE-2011-2523	High

2. Scope & Methodology

Scope: A single target host, 192.168.211.129, located on an isolated, non-production lab network segment reserved for security-training exercises (Metasploitable2).

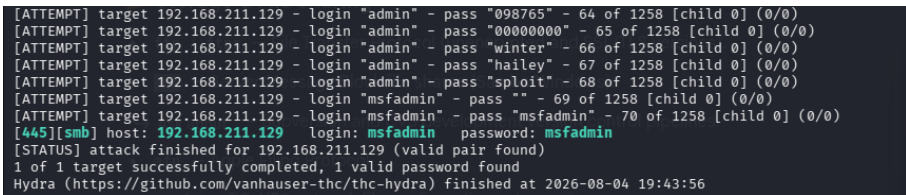
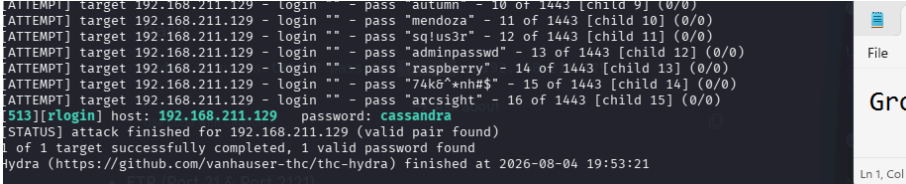
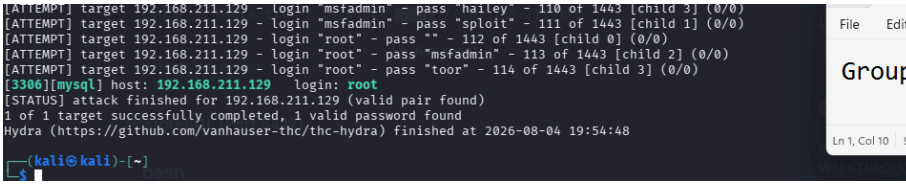
Tools used: THC-Hydra (credential brute-forcing), the native FTP and Telnet clients, OpenSSL, and the OpenSSH client.

Approach: Services were enumerated, common/default and dictionary-based credentials were tested against each exposed service, and any valid credentials were used to gain further access. Discovered access was then used to pivot toward full system compromise.

3. Finding Details

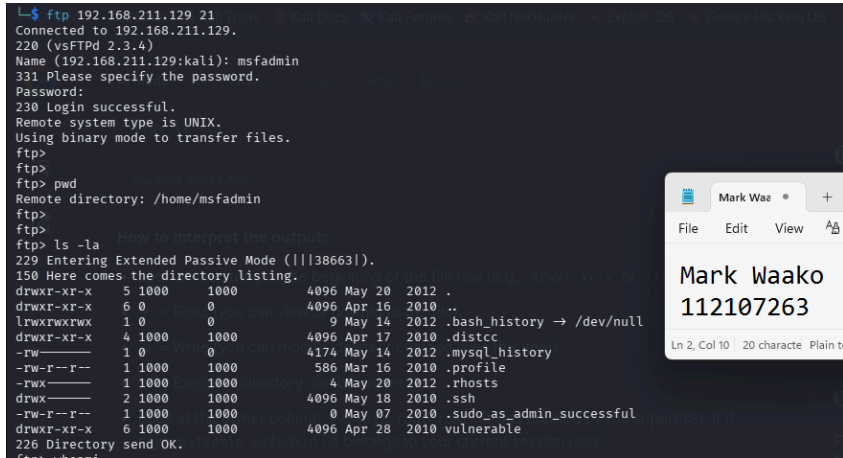
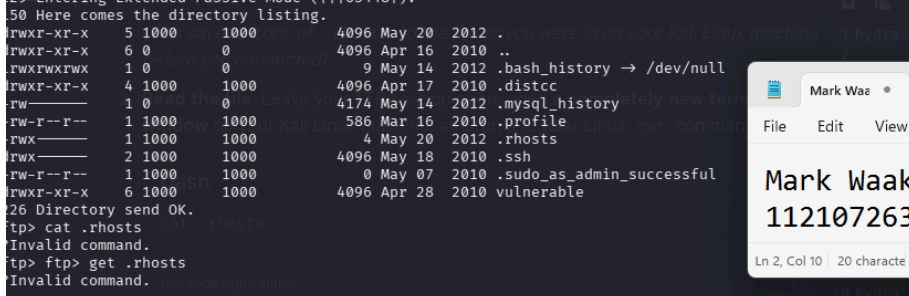
Finding 1: Weak / Default Credentials on Exposed Network Services

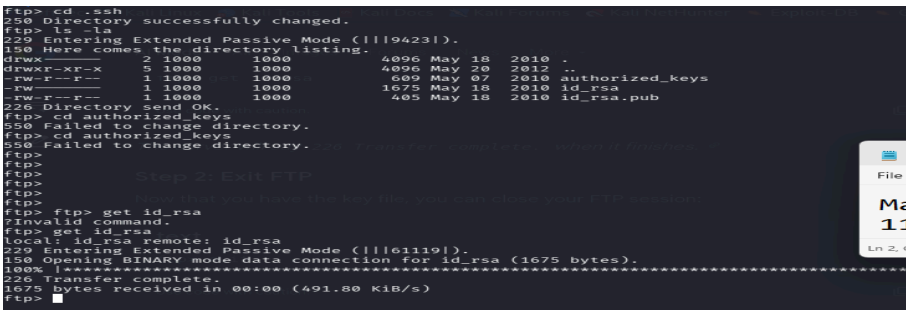
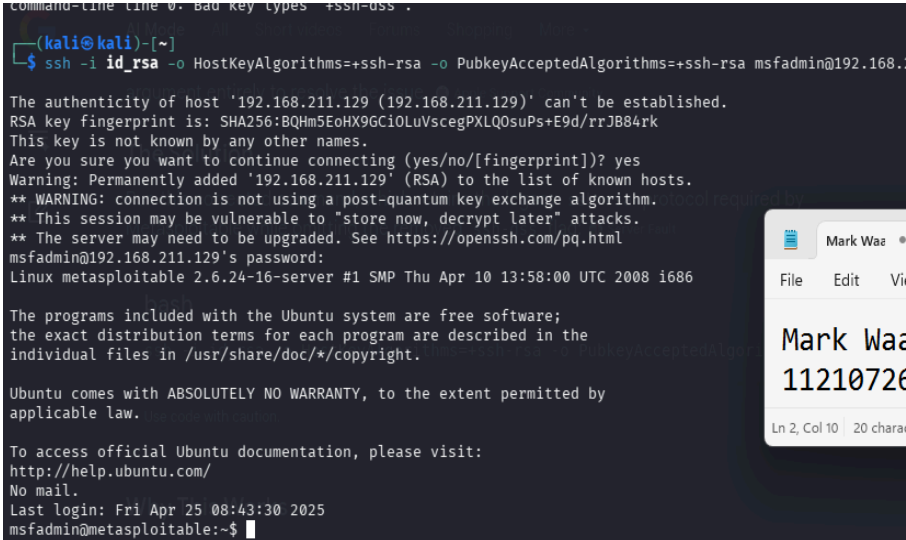
FD1.1 Finding Name	Weak / Default Credentials on Exposed Network Services
FD1.2 Affected Resource	Multiple exposed services on 192.168.211.129: FTP (21), HTTP/Tomcat Manager (80), PostgreSQL (5432), SMB (445), rlogin (513), MySQL (3306)
FD1.3 Method of Finding	Automated credential brute-forcing / dictionary attack using THC-Hydra against each identified open port and service.
FD1.4 Description	Hydra was run against every discovered service using common username and password wordlists. Valid, working credentials were returned for six separate services within minutes, indicating widespread use of default or trivially guessable account passwords across the host. Severity: CRITICAL
FD1.5 Evidence (Screenshots)	<i>Figure 1.1 — Hydra recovers FTP credentials msfadmin:msfadmin</i> <pre>[ATTEMPT] target 192.168.211.129 - login "msfadmin" - pass "autumn" - 78 of 1258 [child 13] (0/0) [ATTEMPT] target 192.168.211.129 - login "msfadmin" - pass "mendoza" - 79 of 1258 [child 14] (0/0) [ATTEMPT] target 192.168.211.129 - login "msfadmin" - pass "sqlus3r" - 80 of 1258 [child 15] (0/0) [ATTEMPT] target 192.168.211.129 - login "msfadmin" - pass "adminpasswd" - 81 of 1258 [child 11] (0/0) [ATTEMPT] target 192.168.211.129 - login "msfadmin" - pass "raspberr" - 82 of 1258 [child 0] (0/0) [21][ftp] host: 192.168.211.129 login: msfadmin password: msfadmin [STATUS] attack finished for 192.168.211.129 (valid pair found) 1 of 1 target successfully completed, 1 valid password found Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-04 19:14:37</pre> <i>Figure 1.2 — Hydra recovers HTTP (Tomcat) password 'toor'</i> <pre>[ATTEMPT] target 192.168.211.129 - login "" - pass "autumn" - 10 of 1258 [child 9] (0/0) [ATTEMPT] target 192.168.211.129 - login "" - pass "mendoza" - 11 of 1258 [child 10] (0/0) [ATTEMPT] target 192.168.211.129 - login "" - pass "sqlus3r" - 12 of 1258 [child 11] (0/0) [ATTEMPT] target 192.168.211.129 - login "" - pass "adminpasswd" - 13 of 1258 [child 12] (0/0) [ATTEMPT] target 192.168.211.129 - login "" - pass "raspberr" - 14 of 1258 [child 13] (0/0) [ATTEMPT] target 192.168.211.129 - login "" - pass "74k6^nh#\$" - 15 of 1258 [child 14] (0/0) [ATTEMPT] target 192.168.211.129 - login "" - pass "arcsight" - 16 of 1258 [child 15] (0/0) [80][http-get] host: 192.168.211.129 password: toor [STATUS] attack finished for 192.168.211.129 (valid pair found) 1 of 1 target successfully completed, 1 valid password found Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-04 19:19:44</pre> <i>Figure 1.3 — Hydra recovers PostgreSQL credentials postgres:postgres</i> <pre>[ATTEMPT] target 192.168.211.129 - login "postgres" - pass "tomcat" - 501 of 1258 [child 4] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "valerie" - 502 of 1258 [child 5] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "spencer" - 503 of 1258 [child 6] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "scarface" - 504 of 1258 [child 9] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "hardcore" - 505 of 1258 [child 3] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "098765" - 506 of 1258 [child 7] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "00000000" - 507 of 1258 [child 12] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "winter" - 508 of 1258 [child 13] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "hailey" - 509 of 1258 [child 14] (0/0) [ATTEMPT] target 192.168.211.129 - login "postgres" - pass "sploit" - 510 of 1258 [child 15] (0/0) [ATTEMPT] target 192.168.211.129 - login "sys" - pass "" - 511 of 1258 [child 0] (0/0) [ATTEMPT] target 192.168.211.129 - login "sys" - pass "msfadmin" - 512 of 1258 [child 8] (0/0) [ATTEMPT] target 192.168.211.129 - login "sys" - pass "toor" - 513 of 1258 [child 11] (0/0) [ATTEMPT] target 192.168.211.129 - login "sys" - pass "mommy" - 514 of 1258 [child 4] (0/0) [ATTEMPT] target 192.168.211.129 - login "sys" - pass "juliana" - 515 of 1258 [child 10] (0/0) [ATTEMPT] target 192.168.211.129 - login "sys" - pass "cassandra" - 516 of 1258 [child 1] (0/0) [5432][postgres] host: 192.168.211.129 login: postgres password: postgres [STATUS] attack finished for 192.168.211.129 (valid pair found) 1 of 1 target successfully completed, 1 valid password found Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-04 19:42:42</pre> <i>Figure 1.4 — Hydra recovers SMB credentials msfadmin:msfadmin</i>

	 Figure 1.5 — Hydra recovers rlogin password 'cassandra'  Figure 1.6 — Hydra recovers MySQL root login (blank/weak password) 
FD1.6 Exploitation	1. Enumerated open TCP ports and running services on 192.168.211.129 (FTP, HTTP, SMB, MySQL, PostgreSQL, rlogin, etc.). 2. Selected THC-Hydra as the brute-force tool, targeting each service with its correct protocol module (ftp, http-get, mysql, smb, rlogin, postgres). 3. Ran Hydra with a common username/password wordlist (~1,258 password candidates) against each service in turn. 4. Recorded each successful [service][port] hit reported by Hydra, confirming valid credential pairs for FTP, HTTP, PostgreSQL, SMB, rlogin, and MySQL. 5. Used the recovered credentials to manually authenticate to each service and confirm access (see Finding 2 for the FTP follow-on).
FD1.7 Impact	Any of these credential sets grants an attacker unauthenticated-equivalent access to sensitive services. In this engagement the recovered FTP credentials (msfadmin:msfadmin) became the initial foothold that ultimately led to full root compromise of the host (see Findings 2 and 3).
FD1.8 Likelihood	High — the credentials tested are well-known defaults / weak dictionary words, requiring no privileged knowledge of the target and are commonly included in every public brute-force wordlist.
FD1.9 Risk Rating	Critical
FD1.10 Recommendations	• Enforce strong, unique passwords for every service account and remove all default/vendor credentials before deployment. • Disable or restrict services that are not required to be network-facing (e.g., rlogin, unauthenticated database access). • Implement account lockout / rate limiting and network-level access control lists on management interfaces such as the Tomcat Manager. • Deploy multi-factor authentication on any remotely accessible administrative service.

- Monitor and alert on repeated authentication failures indicative of brute-force activity.

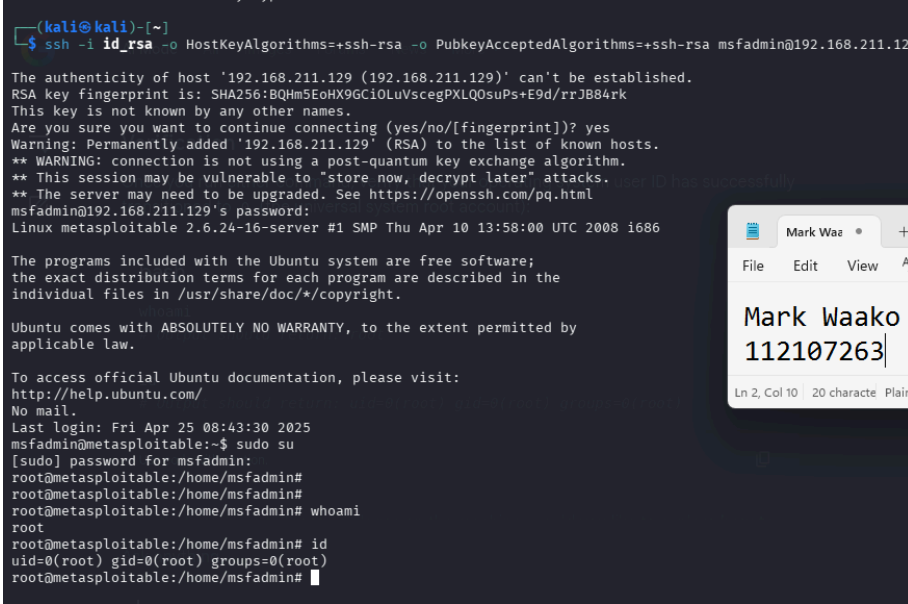
Finding 2: World-Readable SSH Private Key Disclosed via Insecure FTP Permissions

FD2.1 Finding Name	World-Readable SSH Private Key Disclosed via Insecure FTP Permissions
FD2.2 Affected Resource	FTP service (vsftpd 2.3.4), directory /home/msfadmin/.ssh on 192.168.211.129
FD2.3 Method of Finding	Manual post-exploitation enumeration of the FTP account (msfadmin:msfadmin) recovered under Finding 1.
FD2.4 Description	After authenticating to FTP with the credentials recovered in Finding 1, directory listings revealed the msfadmin user's .ssh directory was accessible and its private key file (id_rsa) had permissions allowing it to be read and downloaded over FTP. This key could be used to authenticate over SSH without needing any password at all. Severity: CRITICAL
FD2.5 Evidence (Screenshots)	<i>Figure 2.1 — Successful FTP login as msfadmin and home directory listing</i>  <i>Figure 2.2 — .ssh directory contents visible/readable over FTP</i>  <i>Figure 2.3 — id_rsa and id_rsa.pub listed with weak permissions inside .ssh</i>

	 Figure 2.4 — SSH login as msfadmin using the downloaded private key, no password required 
FD2.6 Exploitation	1. Connected to FTP (port 21) using the msfadmin:msfadmin credentials recovered in Finding 1. 2. Navigated to the user's home directory and listed contents with 'ls -la', revealing a readable .ssh directory. 3. Changed into .ssh and listed its contents, finding id_rsa (private key) and id_rsa.pub with permissions that allowed the files to be read and downloaded through the FTP session. 4. Downloaded the private key using 'mget id_rsa'. 5. Set correct local permissions on the stolen key with 'chmod 600 id_rsa' (required by the SSH client). 6. Authenticated over SSH as msfadmin using 'ssh -i id_rsa msfadmin@192.168.211.129', gaining an interactive shell without ever supplying a password.
FD2.7 Impact	Complete, password-less takeover of the msfadmin account over SSH. Because this account was later found to have unrestricted sudo rights (Finding 3), this single file-permission weakness directly enabled full root compromise of the host.
FD2.8 Likelihood	High — once any valid credential for the host is obtained (see Finding 1), locating and retrieving an overly-permissive private key is a simple, low-effort enumeration step.
FD2.9 Risk Rating	Critical

FD2.10 Recommendations	- Set private key files to 600 (owner read/write only) and store them outside of any directory reachable by a file-transfer service. - Disable anonymous/generic FTP access to user home directories, or chroot each FTP user to a directory that excludes .ssh and other sensitive paths. - Replace unencrypted FTP with SFTP/FTPS and apply the principle of least privilege to exposed file shares. - Rotate any SSH key pairs that may have been exposed and audit authorized_keys / private key permissions across all hosts. - Periodically audit sensitive directories for excessive read permissions using automated configuration-scanning tools.
---------------------------	--

Finding 3: Insecure Sudo Configuration Allowing Privilege Escalation to Root

FD3.1 Finding Name	Insecure Sudo Configuration Allowing Privilege Escalation to Root
FD3.2 Affected Resource	Operating system / sudoers configuration for the msfadmin account on 192.168.211.129
FD3.3 Method of Finding	Manual privilege-escalation attempt following the SSH foothold obtained in Finding 2.
FD3.4 Description	Once authenticated over SSH as msfadmin, a simple 'sudo su' request was accepted using the account's own (weak/known) password, immediately elevating the session to the root account with full system privileges. Severity: CRITICAL
FD3.5 Evidence (Screenshots)	<i>Figure 3.1 — 'sudo su' succeeds and 'whoami'/'id' confirm root access (uid=0)</i>  <pre> (kali@kali)-[~] \$ ssh -i id_rsa -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.211.129 The authenticity of host '192.168.211.129 (192.168.211.129)' can't be established. RSA key fingerprint is: SHA256:BQHm5EoHX9Gci0LuVscgPXLQ0suPs+E9d/rfJB84rk This key is not known by any other names. Are you sure you want to continue connecting (yes/no/[fingerprint])? yes Warning: Permanently added '192.168.211.129' (RSA) to the list of known hosts. ** WARNING: connection is not using a post-quantum key exchange algorithm. ** This session may be vulnerable to "store now, decrypt later" attacks. See https://openssh.com/pq.html msfadmin@192.168.211.129's password: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. To access official Ubuntu documentation, please visit: http://help.ubuntu.com/ No mail. Last login: Fri Apr 25 08:43:30 2025 msfadmin@metasploitable:~\$ sudo su [sudo] password for msfadmin: root@metasploitable:/home/msfadmin# root@metasploitable:/home/msfadmin# root@metasploitable:/home/msfadmin# whoami root root@metasploitable:/home/msfadmin# id uid=0(root) gid=0(root) groups=0(root) root@metasploitable:/home/msfadmin# </pre>
FD3.6 Exploitation	- Established an interactive SSH session as msfadmin using the private key obtained in Finding 2. - Executed 'sudo su' at the shell prompt.

	3. Supplied the msfadmin account password when prompted by sudo. 4. Confirmed elevation by running 'whoami' and 'id', both of which returned uid=0(root) gid=0(root), verifying full root access to the host.
FD3.7 Impact	Full, unrestricted compromise of the operating system: an attacker can read/modify any file, create persistence mechanisms, pivot to other hosts, or destroy data. This represents the worst-case outcome of the initial credential and file-permission weaknesses chained together in Findings 1 and 2.
FD3.8 Likelihood	High — the escalation path required only the account's own weak password and no additional exploit, making it trivial for any attacker who has already reached Finding 2.
FD3.9 Risk Rating	Critical
FD3.10 Recommendations	• Restrict sudo privileges to the specific commands each account requires (principle of least privilege) rather than unrestricted root access. • Remove or disable default training/demo accounts (e.g., msfadmin) from production-like images before deployment. • Require a separate, strong credential for privileged escalation, distinct from the account's login password. • Enable centralized logging/alerting for all sudo usage, especially 'sudo su' and shell-spawning commands. • Apply regular patching and hardening baselines (e.g., CIS Benchmarks) to remove legacy insecure defaults.

4. Additional Observation: Outdated Service Version

The FTP banner returned by the target (vsFTPD 2.3.4) corresponds to a version publicly known to contain a separate, unauthenticated command-execution backdoor tracked as CVE-2011-2523. This backdoor was not the vector used to gain access during this engagement (access was obtained via the weak-credential and file-permission issues in Findings 1–2); however, its presence represents an additional, independent critical-severity exposure that should be remediated by patching or replacing the FTP service, regardless of the credential and permission fixes above.

5. Overall Risk Summary

The combination of weak credentials, insecure file permissions, and an unrestricted sudo configuration allowed a complete, unauthenticated-to-root compromise chain to be executed in under an hour using only publicly available tools. No single finding in isolation is unusual, but their combination on one host represents a Critical overall risk to confidentiality, integrity, and availability of the system and any data it holds.

Remediation of Finding 1 (credentials) and Finding 2 (file permissions) alone would have broken the attack chain before privilege escalation was ever attempted; all identified issues should nonetheless be remediated as defense-in-depth.